13 — Information security policy (public summary)

Français (version de référence) : ../fr/13-politique-securite.md

> **TEMPLATE.** Summary for customers and partners. Every statement must stay true: review it with every version (technical reference: `docs/en/security.md`).

Header	
Jurisdiction	DRC — Digital Code (security obligation of controller and processor)
Assumptions	H-03, H-04, H-15
Sources	S01; audit `docs/en/03-security-audit.md`
Clauses to validate	notification commitment (V-06)
Version	2.0.0 — [DATE]

Our commitments

1. **Your data stays separate**: the database isolates each business (row-level security, enforced by the database itself); our tests check that one business cannot read another's data.
2. **Your communications are encrypted**: the applications only accept HTTPS connections to the server.
3. **Your passwords are never stored in plain text**: they are protected with Argon2id. Minimum 8 characters, very common passwords refused, attempts limited. We will not force you to change it periodically.
4. **Every action is traced**: your business's activity log records who did what; no Nhill feature lets anyone modify or erase it, neither you nor our team (the database role used by the application has no right to do so).
5. **Our team does not access your documents**: the administration console gives access neither to your invoices nor to your customers; direct database access is reserved for technical operations (maintenance, backups); we only look at overall usage figures, and each view appears in your log.
6. **Our administrators use mandatory two-factor authentication.**
7. **Encrypted backups** daily, with restore tests **[only to be stated once production backups are in place and a restore has been tested]**.
8. **No secret in the applications**: they contain no database password or access key.

What we do not promise

No software is free of flaws. Nhill has not yet had an external audit or an independent penetration test; we plan one before a large-scale roll-out and will publish its date.

What we expect from you

One account per person; remove access for employees who leave; a password used only for Nhill (a short sentence is easy to remember); an up-to-date computer with active antivirus; report any suspicious activity to us.

Incidents

If a data breach affects you, we warn you without undue delay (at the latest [24] hours after becoming aware of it) with what we know and the measures taken (procedure: template 14).

Reporting a flaw

[SECURITY E-MAIL] — please do not exploit or disclose the flaw before it is fixed.